

大数据安全教材课件配套的习题作业

第一章

1.8 习题

1. 填空题

- 1) _____年5月25日，GDPR在欧盟全面实施。
- 2) 2021年，我国颁布实施了两部数据安全方面的基础性法律：《_____》和《_____》。
- 3) _____是数字经济时代核心的生产要素。
- 4) 隐私保护不仅要保护用户数据的机密性，还要保护用户行为数据的_____，也就是对用户元数据的保护。

2. 简答题

- 1) 安全与隐私有什么区别？
- 2) 简述个人数据安全与个人隐私的关系。
- 3) 简述技术进步与隐私保护的关系。

1. 填空题

- 1) 2018
- 2) 数据安全法；个人信息保护法
- 3) 数据
- 4) 不可区分性

2. 简答题

- 1) 安全：聚焦数据资产的保密性、完整性、可用性（CIA三要素），防范未授权访问、篡改或破坏。
隐私：侧重个人对自身数据的控制权，确保个人身份、行为等敏感信息不被非法收集、使用或泄露，核心是个人自主性保护。
- 2) 数据安全是隐私保护的基础：通过加密、访问控制等技术手段保障个人数据不被泄露或滥用；隐私是数据安全的最终目标之一：数据安全措施（如匿名化）需服务于隐私保护，但隐私还涉及法律合规（如知情同意）。
- 3) a. 双向影响：
技术进步威胁隐私：大数据分析、人脸识别等技术加剧个人信息滥用风险。
技术增强隐私保护：差分隐私、联邦学习、同态加密等技术实现“数据可用不可见”，提升隐私防护能力。
b. 动态平衡：法律法规（如GDPR）要求技术研发内嵌隐私保护机制。

第二章

2.6 习题

1. 解释完善保密加密的概念。
2. 设计密码算法的启发式方法有哪些？
3. 解释香农的乘积密码设计思想。我们使用的密码算法中有哪些是基于这种设计思想的？
4. 选择分组密码的工作模式时应遵循的基本原则有哪些？
5. 简述利用生日攻击的方法攻击哈希函数的过程。

1. 完善保密加密指密文不泄露任何明文信息的加密方案。即使攻击者拥有无限计算资源，也无法从密文中推断明文（即明文与密文独立 $P(M = m | C = c) = P(M = m)$ ）。
2. 设计密码算法的启发式方法有：混淆（非线性变换），扩散（将明文/密钥的局部变化扩散到整个密文），迭代结构（多轮重复简单操作提升安全性）等。

3. 香农乘积密码设计思想：将多个简单的密码变换（如代换和置换）组合，形成复杂的整体结构，提高安全性。

基本原理：单一变换容易被破解，组合变换可指数级增加攻击难度。

典型实现：DES（Feistel 结构，S 盒 + P 盒）；AES（多轮代换、行移位、列混合、轮密钥加）

4. 分组密码工作模式选择原则

满足安全性需求：不同模式安全特性不同，如 CBC 可隐藏明文模式，ECB 不可。

适应数据特性：流式数据常用 CFB/OFB/CTR；存储数据可用 CBC。

错误传播控制：对错误敏感度有要求时避免使用错误扩散严重的模式。

并行处理能力：CTR、GCM 支持并行加解密；CBC 加密不可并行。

附加功能：如需要完整性验证可选择带认证的模式（GCM、CCM）。

5. 简述利用生日攻击的方法攻击哈希函数的过程。

基于生日悖论：在 n 位哈希中，仅需约 $2^{n/2}$ 次尝试就可能找到碰撞。

攻击步骤：

a. 生成大量随机消息并计算哈希值。

b. 比较结果，寻找相同哈希值的不同消息。

c. 若找到碰撞，可用于伪造签名或破坏完整性验证。

例：对 128 位哈希，碰撞复杂度仅约 2^{64} 次运算。

第三章

3.9 习题

1. 填空题

- 1) TLS 协议可分为_____和_____。
- 2) TLS 协议使用_____来保证前向安全性。
- 3) HMAC 的工作原理是_____。
- 4) 采用 HSTS 策略的网站将保证浏览器始终连接到该网站的_____加密版本。
- 5) DTLS 提供了与 SSL 近似的加密保障，但保留了底层高效的_____传输机制。

2. 选择题

- 1) TLS 握手协议的任务包括（ ）。
 - A. 协商密钥规格
 - B. 利用公钥证书来认证服务器的身份
 - C. 生成会话密钥
 - D. 用会话密钥加密传输的数据
- 2) 以下 HTTPS 的部署模式中，（ ）是最安全的。
 - A. HTTP 和 HTTPS 并存
 - B. HTTP 默认跳转到 HTTPS
 - C. 持久跳转 HTTPS（HSTS）

D. HSTS + HSTS Preload

- 3) 以下（ ）技术是用来解决假冒证书问题的。

A. CT B. HPKP C. CDN D. ACME 协议

3. 术语解释

- 1) HSTS。
- 2) CDN。

4. 简答题

- 1) 简述 TLS 1.3 协议与以前版本的 TLS 协议在握手流程上的区别。
- 2) 简述 HSTS Preload List 的作用与工作原理。
- 3) 简述 Web PKI 的工作原理。
- 4) 简述 ACME 协议的工作原理。
- 5) 简述 CT 和 PKP 的工作原理。
- 6) 简述 Noise 协议框架与 TLS 的不同。
- 7) 阅读以下关于端到端加密的论述，简述你的观点。

SSL 加密标准仅保护用户的设备和互联网公司服务器之间的数据传输安全，保证黑客无法窃取用户在网络中传输的数据，但是并不能保证互联网公司不窥探用户之间的通信数据。这些互联网公司拥有已加密数据的明文数据，它们可以无障碍地访问用户的加密数据。

如果用户愿意使用端到端加密通信，那么上述问题便可以得到解决。信息发送者在本地将信息加密，信息接收者在收到加密信息后本地解密。谷歌等信息传输媒介仅仅能够访问加密信息，而无法阅读和复制你的信息。最古老的电子邮件加密软件之一是 PGP，它诞生于 1991 年。还有加密即时通信软件，它们可以提供加密互联网电话服务。

在 20 世纪 90 年代，赛博朋克运动曾经预言：未来，用户友好的加密软件将会在互联网普及，政府将在技术上无法监控普通人的私人通信。然而，用户友好这个属性与加密软件的天然属性似乎在本质上便存在冲突。现今的加密软件也并不比 30 年前的加密软件更加用户友好。当安全性与易用性发生冲突时，用户就必须在方便易用和强安全性之间做出抉择。绝大多数人的优先选择是方便易用。比起加密通信软件，主流通信软件对用户更加友好，拥有很多加密软件难以支持的功能。

1. 填空题

- 1) 握手阶段；安全通信阶段
- 2) DHE 算法
- 3) $H(K \text{ XOR } \text{opad} || H(K \text{ XOR } \text{ipad} || \text{text}))$
- 4) HTTPS
- 5) UDP

2. 选择题

- 1) ABC 2) D 3) A

3. 术语解释

- 1) HSTS (HTTP Strict Transport Security, HTTP 严格传输安全) 是 IETF 发布的一种互联网安全策略机制。采用 HSTS 策略的网站将保证浏览器始终连接到该网站的 HTTPS 加密版本，不需要用户手动在 URL (统一资源定位符) 地址栏中输入加密地址，以减少会话劫持风险。
- 2) 内容分发网络 (Content Delivery Network, CDN) 是一种分布式基础设施，可以有效地向最终用户提供网站的内容。

4. 简答题

- 1) ①减少往返次数：TLS 1.3 将握手从 2-RTT 缩减为 1-RTT，支持 0-RTT。
②移除不安全算法：去掉 RSA、静态 DH 握手，只保留 ECDHE 提供前向安全性。
③加密范围扩大：握手消息更早进入加密状态，减少被窃听风险。
④性能提升：更快的握手与更强的安全性。
- 2) 作用：让浏览器在首次访问网站时也强制使用 HTTPS，避免第一次连接被劫持。
原理：网站管理员向浏览器厂商提交域名，浏览器内置一份“预加载列表”，用户访问该域名时直接走 HTTPS。
- 3) 基于数字证书与信任链：①浏览器内置根证书。②服务器证书由受信任 CA 签发。③客户端通过验证证书链确保服务器身份合法。从根证书 → 中间证书 → 网站

证书逐级验证，建立信任。

4) ACME 协议是自动化证书管理协议（由 Let's Encrypt 推广）。

工作流程：①客户端向 CA 请求证书。②CA 验证域名所有权（DNS 记录/HTTP 文件验证）。③验证通过后，自动签发证书。④客户端定期通过 ACME 自动续期证书。

5) CT：所有证书必须公开记录到透明日志（不可篡改的日志服务器）；浏览器检查证书是否在日志中，防止伪造或私签证书。

PKP：网站声明自己只接受特定公钥（Pin）；浏览器连接时必须匹配 Pin，否则拒绝连接；缺点：一旦配置错误可能导致网站“锁死”，因此现在较少使用。

6) Noise 协议框架：一个模块化的加密握手框架，可快速构建安全协议；轻量、灵活，广泛用于即时通讯（如 Signal）。

与 TLS 的不同：①Noise 是框架，TLS 是固定协议。②Noise 没有 PKI 内置信任机制，而 TLS 依赖 Web PKI。③Noise 设计简洁，更适合小型应用；TLS 复杂，适合 Web 生态。

第四章

4.8 习题

1. 填空题

- 1) 身份认证中的四个基本原语分别是_____、_____、_____、_____。
- 2) FIDO 协议主要包含_____和_____两套协议。
- 3) Kerberos 协议的主要概念中，票据（Ticket）是用于向服务器认证身份的凭证。主要有两类，分别是_____和_____。
- 4) OAuth 2.0 主要涉及四种角色，分别是：_____、_____、_____和_____。
- 5) OPAQUE 协议可以抵抗_____攻击。

2. 选择题

- 1) 如果是 68 个可用字符，需要长度为（ ）的口令才能达到 128 位安全长度。
A. 8 B. 16 C. 21 D. 32
- 2) 存储口令时，更加安全的口令存储方案是：故意增加密码计算所需资源和时间，使得任何人都不可获得足够的资源建立暴力破解所需的彩虹表。这类方案的常用算法有三种，分别是（ ）。
A. PBKDF2 B. BCRYPT
C. SCRYPT D. BeyondCorp
- 3) 用来实现单点登录的协议包括（ ）。
A. Kerberos 协议 B. OAuth 协议
C. OpenID Connect 协议 D. aPAKE 协议

3. 术语解释

- 1) MFA。
- 2) Cookie。

4. 简答题

- 1) 简述口令认证的优点和缺点。
- 2) 简述基于硬件安全的数字证书的优缺点。
- 3) 简述 FIDO2 与 FIDO UAF 和 FIDO U2F 之间的区别和联系。
- 4) 简述 OAuth 2.0 与 OpenID Connect 在工作流程上的区别。
- 5) 简述 Cookie 劫持攻击的基本原理。
- 6) 简述 OPAQUE 协议的基本原理。

1. 填空题

- 1) 口令；安全令牌；生物特征；公钥（证书）
- 2) UAF;U2F

- 3) 票据许可票据; 服务票据
- 4) 资源所有者; 客户端; 授权服务器; 资源服务器
- 5) 预计算攻击

2.选择题

- 1) C
- 2) ABC
- 3) ABC

3.术语解释

1) 多因子认证 (Multi-Factor Authentication, MFA) 是一种安全认证过程, 需要用户提供两种及以上不同类型的认证因子来表明自己的身份, 以便获得系统或设备的访问权限。它可以提高认证的安全性。

2) Cookie 是存储在客户机上的文本文件。当用户浏览互联网时, 服务器端的代码就可以在用户的计算机上创建一个很小的文本文件, 称为 Cookie (小甜饼)。当该用户再次访问同一站点时, 服务器就可以根据 Cookie 来识别该用户。

4.简答题

1) 优点: ①使用简单, 用户易于理解 and 操作; ②部署成本低, 不依赖额外硬件或复杂系统; ③普遍兼容, 几乎所有系统和应用都支持。

缺点: ①容易被弱口令、重复口令攻击; ②易遭受字典攻击、暴力破解、钓鱼攻击; ③难以抵抗中间人攻击和数据库泄露; ④用户记忆负担大, 容易遗忘或写在不安全的地方。

2) 优点: ①私钥存储在硬件中 (如智能卡、TPM、安全令牌), 不易被导出, 安全性高; ②提供强身份认证, 抵御伪造和重放攻击; ③符合高等级安全要求, 适用于金融、政务等场景。

缺点: ①成本较高 (硬件采购、管理、维护); ②使用不够便捷, 需要额外设备; ③硬件丢失或损坏会导致认证困难。

3) FIDO UAF (Universal Authentication Framework): 无密码认证框架, 用户通过生物特征 (指纹、人脸识别) 或本地 PIN 登录。

FIDO U2F (Universal Second Factor): 双因素认证方案, 使用安全密钥 (如 USB Key) 作为额外因子, 保护现有用户名+密码体系。

FIDO2: 整合并扩展了 UAF 和 U2F, 包括 WebAuthn API 和 CTAP 协议, 支持无密码登录和强认证, 兼容浏览器与平台。

联系: FIDO2 是 UAF 与 U2F 的继承和发展; 都基于公钥加密, 强调“私钥在本地安全存储”; 都不依赖传统密码, 提升抗钓鱼能力。

4) OAuth 2.0: 授权协议, 允许用户授予第三方应用访问资源服务器的权限, 而无需暴露密码。例如允许第三方应用读取用户的谷歌相册。

OpenID Connect (OIDC): 建立在 OAuth 2.0 之上的身份认证层, 增加了 ID Token, 用于确认“用户是谁”。

区别: OAuth 2.0 解决“授权”问题, 侧重资源访问控制; OpenID Connect 解决“认证”问题, 侧重确认用户身份; OIDC 的流程在 OAuth 2.0 基础上增加了身份令牌的交换。

5) ①Cookie 存储用户的会话信息 (如登录状态)。

②攻击者通过网络嗅探、中间人攻击、XSS 脚本注入 等手段窃取 Cookie。

③一旦攻击者获取了有效 Cookie, 就能伪装成用户, 绕过登录过程, 直接访问系统资源。

OPAQUE 协议通过把不经意伪随机函数（Oblivious Pseudorandom Function，OPRF）和 AKE 协议结合起来的这种方案构造。不经意伪随机函数是双方参与计算的一种方式，其中一方为计算提供输入，而另一方执行计算。“不经意”指的是协议性质，执行计算的一方对所提供的输入一无所知，而提供实际输入的一方只学习输出，而对计算没有任何了解。OPAQUE 协议由三条消息组成，服务器和客户端分别需要三次和四次求幂，提供前向保密和显式相互认证，不需要 PKI，支持用户端密码强化，具有基于密码的存储和检索密钥和证书的内置功能，并适应一种用户透明的服务器端阈值实现。

5.6 习题

- 1) 云计算的三种主要服务模式包括：_____、_____、_____。
- 2) 容器技术的三个核心概念包括：_____、_____、_____。
- 3) 如果一个容器可以访问到外面的资源，甚至获得宿主主机的权限，这就叫作“_____”。
- 4) 英特尔 CPU 中存在的漏洞具有两种攻击模式，分别是_____、_____。
- 5) 在谷歌的大数据处理系统中，最广为人知的三项云计算技术是_____、_____、_____。

[illegible][illegible][illegible]

2) PIR.

- 1) 简述虚拟机与容器的区别。
- 2) 简述造成容器逃逸的两类原因与应对措施。
- 3) 简述 Meltdown 和 Spectre 的区别。
- 4) 简述 POR 技术的基本原理。
- 5) 简述加密去重技术的基本原理。

- 1) SaaS;PaaS;IaaS
- 2) 镜像; 容器; 仓库
- 3) Docker 容器逃逸
- 4) Meltdown;Spectre
- 5) MapReduce 计算架构; 谷歌文件系统 (GFS); Bigtable 数据管理系统

2.选择题

- 1) ABC
- 2) ABCD
- 3) ABC

3.术语解释

1) 沙箱容器：在主机操作系统和容器里面运行的应用程序之间提供一道安全的隔离边界。

2) PIR: 私有信息检索 (Private Information Retrieval, PIR) 是指用户在不泄露自己查询信息给数据库的情况下, 完成对数据库的查询操作。

4.简答题

1) 虚拟机 (VM): 通过 Hypervisor 虚拟化整个硬件环境, 每个 VM 拥有独立的操作系统内核, 资源隔离性强, 但启动慢、开销大。

容器 (Container): 基于操作系统级虚拟化, 共享宿主机内核, 仅隔离用户空间, 启动快、占用资源少, 但隔离性弱于虚拟机。

2) 原因一: 软件漏洞。①由于内核漏洞引起的逃逸。因为 Docker 会直接共享宿主机内核, 所以宿主主机的内核存在安全漏洞会一并影响 Docker 的安全, 从而造成 Docker 逃逸。②由于 Docker 软件设计引起的逃逸。

原因二: 错误的配置。攻击者利用宿主机内核缺陷突破隔离。应对措施: 及时更新内核和容器运行时, 采用 SELinux/AppArmor 等安全机制。

3) Meltdown: 利用乱序执行绕过内核与用户空间的隔离, 直接读取内核敏感数据。影响主要在 Intel CPU。

Spectre: 利用分支预测和投机执行误导程序, 跨越进程边界泄露数据。影响范围更广 (Intel、AMD、ARM)。

区别: Meltdown 攻击更直接, 易修复; Spectre 攻击更复杂, 难以彻底消除。

4) POR (Proof of Retrievability, 可检索性证明): 一种远程数据完整性验证技术。

基本原理: ①客户端在上传数据前生成认证标签/编码块; ②验证时, 服务器返回数据片段和认证信息; ③客户端通过验证证明服务器确实完整保存了数据, 而无需取回全部数据。

5) 目标: 在云存储中既能保证隐私, 又能实现数据去重 (节省存储)。

基本原理: 最早提出的方案是 CE: 当需要加密一个数据块 d 的时候, CE 先用数据内容生成密钥, 再用一个对称加密算法加密。

第六章

6.7 习题

1. 填空题

- 1) 安全多方计算模型可以分为_____和恶意模型。
- 2) SGX 是 Intel 架构新的扩展, 在原有架构上增加了_____和_____。
- 3) 可信操作系统启动包括两种情况: _____和_____。

2. 选择题

SGX 与 TrustZone 技术相比, 其优势为 ()。

- A. 支持虚拟化技术、容器技术
- B. 将系统的可信计算基缩小到 CPU
- C. SGX 可抵御侧信道攻击
- D. 通过内存泄露攻击获取关键信息的难度更大

3. 术语解释

- 1) 同态加密。
- 2) 安全多方计算。
- 3) 零知识证明。
- 4) 混淆电路。

4. 简答题

- 1) 简述 Rich OS、TEE 与 SE 的异同。
- 2) 在 Paillier 加密算法的正确性与安全性方面:
 - ① 为什么 Paillier 加密算法是语义安全的?
 - ② 为什么 Paillier 加密算法密文长度是其明文长度的 2 倍?
 - ③ 对于同一个明文 m , 为什么每次 Paillier 密码算法加密出来的密文不同, 却都能够正确解密出明文 m ? 请予以证明。
- 3) 关于同态加密:
 - ① 简述同态加密的定义。
 - ② 证明 RSA 算法是乘法同态的。
 - ③ 证明 Paillier 算法是加法同态的。

1. 填空题

- 1) 半诚实模型
- 2) 一组新的指令集; 内存访问机制
- 3) Trusted OS 首先启动; Trusted OS 按需启动

2. 选择题

ABD

3. 术语解释

- 1) 在密码学中, 记加密操作为 E , 解密操作为 D , 明文为 m , 加密得 c , 即 $c=E(m)$, $m=D(c)$ 。已知针对明文有操作 f , 针对 E 可构造 F , 使得 $F(c)=E(f(m))$, 这样 E 就是一个针对 f 的同态加密算法。
- 2) 安全多方计算 (Secure Multi-party Computation) 由姚期智在 1982 年提出, 主要针对的问题是如何在没有可信第三方的情况下, 安全地对参与方的输入进行计算, 同时不向参与方展示除计算结果外的任何信息。
- 3) 零知识证明: 不会将证据泄露给验证者的知识证明
- 4) 混淆电路: 混淆电路 (GC) 协议是一种加密协议, 可实现两方安全计算, 其中两个互不信任的参与方可以在没有可信第三方存在的情况下共同评估其私有输入的函数。

4. 简答题

- 1) Rich OS: 普通操作系统 (如 Linux/Windows/Android), 功能丰富、运行应用多, 隔离性弱, 攻击面大。
TEE (Trusted Execution Environment): CPU/芯片内的受信任执行环境 (如 TrustZone/SGX), 提供软硬件结合的隔离与密钥保护, 适中资源与较好性能。
SE (Secure Element): 独立的安全芯片/智能卡, 抗篡改强、用于高安全密钥存储和敏感操作, 但资源最受限、开发部署成本高。
共同点: 都用于保护敏感数据与执行可信逻辑; 可组合使用 (Rich OS 提供服务界面, TEE/SE 做可信操作)。
- 2)
 - 2.1) 为什么 Paillier 是语义安全的?
基于决策复合剩余性 (DCR) 假设: 在不知道私钥的情况下, 观察到 $g^m r^N$ 与随机元

素无法区分，因此攻击者不能从密文推断明文 $\rightarrow$ IND-CPA（语义安全）。

2.2) 为什么密文长度约为明文长度的 2 倍？

明文 $m \in Z_N$ （模 N ，长度约 $\log_2 N$ 位）；密文 $c \in Z_{N^2}^*$ （模 N^2 ，长度约 $\log_2 N^2 = 2\log_2 N$ ），所以密文位长约为明文的两倍。

2.3) 同一明文每次加密不同但能正确解密的证明：

加密：选随机 $r \in Z_N^*$ ，计算 $c = g^{mr^N} \bmod N^2$ 。不同 $r \rightarrow$ 不同 c 。

解密（关键步）：计算 $c^\lambda \bmod N^2 = (g^{mr^N})^\lambda \equiv g^{m\lambda} \bmod N^2$ （因为 $(r^N)^\lambda \equiv 1$ ），用函数 $L(u) = (u - 1)/N$ 得到与 m 线性相关的值，除以常数 $L(g^\lambda)$ 得到 m 。

因此随机 r 只改变掩盖项 r^N ，不影响通过 c^λ 提取明文的过程，解密仍返回原 m 。

3)

3.1) 若加密算子 E 在密文空间有运算 $\circ$ ，使得对任意明文 m_1, m_2 ：

$D(E(m_1) \circ E(m_2)) = m_1 * m_2$ ，则称 EEE 对明文运算 $*$ 是同态的。

3.2) RSA 加密： $E(m) = m^e \bmod N$ 。

两密文乘积： $E(m_1)E(m_2) = m_1^e m_2^e = (m_1 m_2)^e \bmod N$ 。

解密得 $(m_1 m_2)^{ed} \equiv m_1 m_2 \bmod N$ 。

$\rightarrow$ RSA 对乘法同态。

3.3) Paillier 加密： $E(m) = g^{mr^N} \bmod N^2$ 。

乘积： $E(m_1)E(m_2) = g^{m_1 r_1^N} \cdot g^{m_2 r_2^N} = g^{m_1 + m_2} (r_1 r_2)^N \bmod N^2$ 。

该乘积即为对明文 $m_1 + m_2$ 的合法加密，解密得到 $m_1 + m_2 \bmod N \rightarrow$ Paillier 对加法同态。

第七章

7.10 习题

1. 填空题

1) 在具体应用中，_____即数据所有者不愿意披露的敏感信息，包括敏感数据以及数据所表征的特性。

2) 若 s 表示敏感数据，事件 S_k 表示“攻击者在背景知识 K 的帮助下揭露敏感数据 s ”，则披露风险 $r(s, K)$ 表示为_____。

3) 对于任意一对相邻数据库（定义为差别最多有一个记录的两个数据库） D_1 和 D_2 ，任意一个可能的带噪中间件 S ，一个提供 ϵ -差分隐私保护的算法 M 必须满足不等式_____。

4) 本地化差分隐私的定义为：给定 n 个用户，每个用户拥有一条记录，如果算法 M 对任意两条记录 t 和 t' ，得到相同输出结果 t^* 的可能性满足不等式_____，则说明其满足 ϵ -本地化差分隐私。

5) _____算法是谷歌提出的基于随机响应的一个通用差分隐私算法，主要用于收集用户的数据并能保证用户的隐私。

2. 选择题

- 1) () 是常见的隐私保护模型。
A. k 重匿名 B. ℓ -多样化 C. t 相近 D. 高斯机制
- 2) () 机制是中心化差分隐私领域的基础机制。
A. 拉普拉斯机制 B. 高斯机制
C. 指数机制 D. 随机响应机制
- 3) 差分隐私使用 () 添加随机扰动的方式, 来保证机器学习模型的隐私保护。
A. 输入扰动 B. 中间参数扰动
C. 目标扰动 D. 输出扰动

3. 术语解释

- 1) 抑制。
- 2) 泛化。

4. 简答题

- 1) 简述 k 重匿名如何抵御记录链接攻击。
- 2) 简述 ℓ -多样化如何抵御属性链接攻击。
- 3) 分别简述拉普拉斯机制、高斯机制和指数机制的基本原理, 以及三者之间的区别。
- 4) 简述中心化差分隐私和本地化差分隐私的区别。
- 5) 分别简述随机响应机制和一元编码机制的基本原理。
- 6) 简述 RAPPOR 算法的具体步骤。

1. 填空题

- 1) 隐私
- 2) $r(s, K) = \Pr(S_k)$
- 3) $\Pr[M(D_1) = S] \leq \exp(\epsilon) \cdot \Pr[M(D_2) = S]$
- 4) $\Pr[M(t) = t^*] \leq e^\epsilon \times \Pr[M(t') = t^*]$
- 5) RAPPOR

2. 选择题

- 1) ABC 2) A 3) ABCD

3. 术语解释

- 1) 抑制: 管理员修改识别字段。他可能会抑制这些识别字段, 把表中的字段完全删除。
- 2) 泛化 (Generalization): 为了更好地实现效用和隐私之间的平衡, 管理者可能会泛化而 不是抑制标识符。这意味着他将改变而不是删除标识符值以增强隐私, 同时保持数据的实用性。

4. 简答题

- 1) k -重匿名 (k -anonymity): 通过泛化/抑制, 使得每条记录在准标识符 (QID) 上与至少 $k-1$ 条记录相同。
抵御原理: 攻击者即使知道某人 QID 信息, 也只能将其与至少 k 条候选记录匹配, 无法唯一确定, 从而抵御记录链接攻击。
- 2) l -多样化 (l -diversity): 在每个等价类中, 敏感属性至少有 l 种“充分不同”的取值。
抵御原理: 即使攻击者定位到某个等价类, 也无法推断出敏感属性, 因为存在至少 l 种可能, 从而抵御属性链接攻击。
- 3) 拉普拉斯机制: 在查询结果上加入服从 $Laplace(0, \Delta f / \epsilon)$ 分布的噪声。
高斯机制: 在结果上加入服从 $Gaussian(0, \sigma^2)$ 的噪声。
指数机制: 对离散输出集合, 按效用函数分数加权, 概率性选择输出, 满足差分隐私。
区别:

拉普拉斯机制：适合精确的 ϵ -差分隐私，常用于数值查询。

高斯机制：适合 (ϵ, δ) -差分隐私，更灵活，常用于统计学习。

指数机制：适合非数值结果的选择问题（如推荐、分类）。

4) CDP 假设有可信的 centralized 数据持有方；LDP 不依赖信任，隐私更强，但数据可用性和准确度相对下降。

5) 随机响应 (Randomized Response)：用户对真实答案进行随机翻转，例如“是/否”问题中以某个概率回答真值，以另一概率回答反值。保护个体隐私，同时统计上仍可恢复总体分布。

一元编码 (Unary Encoding, UE)：将用户的真实取值编码为一个 one-hot 向量，然后随机翻转其中的比特位，从而保护隐私。

区别：UE 是随机响应在多值域上的推广，适用于多选或分类场景。

6) 编码：将用户敏感数据映射为独热编码。

扰动阶段一：固定随机扰动，保证长期隐私。

扰动阶段二：在每次上报前再次随机扰动，防止多次收集攻击。

收集与聚合：服务端收集大量扰动后的数据向量。

统计估计：通过概率反演和聚合，恢复总体分布，而个体隐私仍得到保护。

第八章

8.7 习题

1. 填空题

1) 科学的发展，是一个知识积累的过程。知识的发现和构建离不开四个方面的工作：

_____、_____、_____、_____。

2) 根据攻击造成的效果不同，可以将针对推荐系统的伪造共同访问攻击分成两类：

_____和_____。

3) _____是指在原数据集中通过人工添加肉眼不可见或者经处理不影响整体的肉眼可见的细微扰动所形成的样本。

4) 联邦学习旨在建立一个基于_____的联邦学习模型。

5) 基于安全多方计算的隐私保护机器学习有三种架构，分别是_____、_____和_____。

2. 选择题

1) 以下 () 攻击是机器学习隐私攻击。

- A. 成员推理攻击 B. 模型逆向攻击
C. 后门攻击 D. 模型萃取攻击

2) CIA 安全模型是指攻击者可以破坏机器学习模型的 () 性质。

- A. 机密性 B. 完整性 C. 可用性 D. 一致性

3) 以下 () 技术是保护机器学习隐私的常见技术。

- A. 同态加密技术 B. 安全多方计算技术
C. 差分隐私计算技术 D. 区块链技术

3. 术语解释

1) 众包。

2) SEO。

4. 简答题

1) 简述机器学习的基本原理。

2) 简述对抗样本攻击、数据投毒攻击和后门攻击之间的区别。

3) 简述三种机器学习隐私攻击之间的区别。

4) 简述在训练数据时，集中式学习、分布式学习和联邦学习三种方式的区别。

5) 简述三种保护机器学习隐私常见技术适合的应用场景。

1.填空题

- 1) 基于观察与实验来提出假设；基于假设来构建模型；基于实践对模型进行验证;构建理论体系对其本质做出合理解释
- 2) 提升攻击；降级攻击
- 3) 对抗样本
- 4) 分布数据集
- 5) 安全客户端-服务器架构；安全外包计算架构；安全联邦学习架构

2.选择题

- 1) ABD
- 2) ABC
- 3) ABC

3.术语解释

- 1) 众包（Crowdsourcing）是指把一个问题分解为很多子问题，然后把这些子问题外包给分布在不同地域的大众，然后聚合其结果，计算出最终的答案。
- 2) 搜索引擎优化（SEO）是指通过了解各类搜索引擎如何抓取互联网页面、如何进行索引以及如何确定其对某一特定关键词的搜索结果排名等技术，来对网页内容进行相关优化，使其符合用户浏览习惯，在不损害用户体验的情况下提高网站在搜索引擎上的排名，从而提高网站访问量，最终提升网站的销售能力或宣传能力的技术。

4.简答题

- 1) 机器学习通过数据训练模型，让模型自动学习数据中的规律，并用于预测或分类。
基本流程：数据准备 → 特征提取 → 模型训练 → 模型评估 → 应用预测。
- 2) 对抗样本攻击：在输入数据上加小扰动，使模型预测错误。
数据投毒攻击：在训练数据中加入恶意数据，影响模型训练结果。
后门攻击：在训练阶段植入隐藏触发器，触发时模型输出攻击者指定结果。
- 3) 模型逆向攻击：推测训练数据的敏感属性。
成员推理攻击：判断某条数据是否在训练集里。
模型萃取攻击：通过黑箱访问复制或近似原始模型。
- 4) 集中式学习：所有数据集中到一台服务器训练。
分布式学习：数据分布在多机器上，但原始数据仍需共享或同步。
联邦学习：数据留在本地，只上传模型参数更新，保护数据隐私。
- 5) 差分隐私（DP）：在统计结果或参数中加噪声，适合保护用户隐私数据（如医疗、金融）。
同态加密（HE）：在加密数据上直接做运算，适合云端安全计算。
安全多方计算（MPC）：多方共同计算但不泄露各自数据，适合多机构联合训练（如跨医院、跨公司）。

第九章

9.8 习题

1. 填空题

1) 匿名通信系统的路径拓扑有两种，其中基于 Mix 算法的匿名通信采用的是_____。

2) 匿名通信中，匿名属性包括不可辨识性和_____。

2. 选择题

发起者需要在发起匿名通信之前确定整个通信的传输路径的是（ ）。

- A. 基于 Mix 算法的匿名通信
- B. 基于洋葱路由算法的匿名通信
- C. 基于泛洪算法的匿名通信
- D. Tor 匿名通信

3. 术语解释

- 1) 匿名通信。
- 2) 在线追踪。

4. 简答题

- 1) 简述洋葱网络的工作原理。
- 2) 简述基于 Cookie 在线跟踪技术的工作原理。

1.填空题

- 1) 瀑布型
- 2) 不可联系性

2.选择题

- 1) A

3.术语解释

- 1) 匿名通信是指采取一定的措施隐蔽通信流中的通信关系，使窃听者难以获取或推知通信双方的关系及内容的通信模式。
- 2) 在线追踪技术是指网站、应用或第三方服务通过收集用户在网络上的行为数据（如浏览记录、点击习惯、设备信息、位置信息等），在用户不知情或未完全同意的情况下，对其进行标识、跟踪和画像的技术手段。

4.简答题

- 1) 用户的数据在发送前会被多层加密，每一层对应一台中继节点。数据在网络中逐跳传输，每个节点只解密自己那一层加密，得到下一个节点的地址并转发。这样，任何单一节点都无法知道数据的完整来源和目的地，从而实现匿名通信。
- 2) 网站在用户浏览器中存储一小段数据（Cookie），记录用户标识和行为信息。当用户再次访问该网站或与第三方广告商合作的网站时，浏览器会自动携带 Cookie 信息。这样，网站或第三方可以跨会话、跨网站跟踪用户的访问习惯，实现用户画像和精准广告投放。

10.5 习题

1. 填空题

- 1) _____是指按照数据具有的某种共同属性或特征，采用一定的原则和方法进行区分和归类。
- 2) _____是指按照数据遭到破坏后对国家安全、社会秩序、公共利益以及个人、法人和其他组织的合法权益（受侵害客体）的危害程度对数据进行定级。
- 3) _____是指通过一定的技术和管理，防止组织内敏感数据或信息资产，因违反安全约束而丧失组织控制、数据机密性被破坏的策略和措施。
- 4) DLP 的三种主流形态分别是_____、_____、_____。

2. 简答题

- 1) 简述数据分类和数据分级的区别。
- 2) 简述 IDM 和 SVM 比对的区别。

1.

- (1) 数据分类
- (2) 数据分级
- (3) 数据防泄漏
- (4) 终端DLP、网络DLP、存储DLP

2.

- (1) 简述数据分类和数据分级的区别。

依据不同：数据分类是根据数据的属性、特征或业务类别（如客户信息、经营数据）进行划分，解决的是“数据是什么”的问题；数据分级是根据数据泄露或破坏后可能造成的危害程度（如对国家安全、公共利益的影响）进行划分，解决的是“数据有多重要”的问题。

目的不同：分类是为了方便管理和业务使用；分级是为了确定保护的优先级和安全策略的强度（级别越高，保护越严）。

关系：通常先进行分类，再在各类别下进行分级。

- (2) 简述 IDM 和 SVM 比对的区别。

IDM 比对通常指基于身份或标识信息的直接匹配，比对规则明确，结果直观，适用于结构化、确定性强的数据；

SVM 比对基于支持向量机的机器学习方法，通过训练模型进行相似度或类别判断，适用于复杂、非线性、特征维度较高的数据；

IDM 偏规则与精确匹配，SVM 偏智能分析与概率判断。